Continuous Improvement

1. Objective

Establish a process for the **continuous improvement** of risk management activities related to the Electronic Patient Information System by using monitoring and review results to identify weaknesses, implement improvements, and verify their effectiveness.

2. Scope

Continuous improvement applies to:

- **Risk identification, analysis, and assessment.**
- **Risk treatment decisions and implementation plans.**
- **Security and administrative controls.**
- **Risk monitoring and review activities.**
- Roles, responsibilities, and system management procedures.

The scope is limited to the Electronic Patient Information System.

3. Concept of Continuous Improvement

Continuous Improvement is an ongoing process of developing risk management by:

- Analyzing monitoring and review results.
- Identifying weaknesses and improvement opportunities.
- Implementing corrective or improvement actions.
- Verifying that these actions are effective.

The main purpose is to address problems, prevent recurrence, and improve risk management over time.

4. Sources of Improvement Opportunities

Improvement opportunities may come from:

- **Monitoring and review results.**

- Security incidents and technical problems.
- **Ineffective or insufficient controls.**
- Backup restoration test failures.
- Access permission review results.
- New threats and security vulnerabilities.
- Changes to the system or cloud provider.
- User feedback.
- Risk treatment implementation reviews.

5. Continuous Improvement Methodology

The process follows seven main steps:

1. **Identify Improvement Opportunities:** Identify problems, weaknesses, or areas requiring improvement.
2. **Analyze Root Causes:** Determine the underlying reason behind the problem.
3. **Determine Improvement Actions:** Select appropriate corrective or improvement measures.
4. **Assign Responsibility:** Define the responsible party, deadline, and required resources.
5. **Implement Actions:** Execute approved improvements and retain evidence.
6. **Verify Effectiveness:** Confirm that the action addressed the problem and achieved its intended result.
7. **Document and Update:** Record the results and update relevant risk management documents.

Important: Implementing an action does not automatically prove that it is effective.

6. Practical Examples

Problem	Improvement Action	Verification
Insufficient account protection	Introduce **Multi-Factor Authentication (MFA)**	Verify MFA activation
Delayed account deactivation	Improve employee departure and account deactivation procedures	Review deactivation records
Backup restoration failure	Improve backup and recovery procedures	Repeat restoration testing

Delayed detection of unusual activity	Improve security monitoring and alerting	Test alerts and review logs
Newly identified vulnerability	Remediate the vulnerability and update affected components	Perform a follow-up security scan

These are **proposed improvements**, not confirmed implemented controls.

7. Responsibilities

- **Hospital Management:** Oversees improvement activities, approves necessary actions, and provides resources.
- **System Administrator:** Identifies technical problems, implements approved technical improvements, and provides evidence.
- **Doctors and Registration Staff:** Report problems and provide feedback related to system usage.
- **Cloud Service Provider:** Implements improvements related to hosting services according to the service agreement.

8. Documentation of Improvement Actions

Each improvement action must be documented with:

- **Action ID**
- Problem or improvement opportunity
- Related risk or control
- **Root Cause**
- Corrective or improvement action
- **Responsible Party**
- Target completion date
- Implementation status
- **Implementation Evidence**
- **Effectiveness Verification Result**
- Closure date

9. Relationship with Risk and Control Records

Improvement results may require updates to:

- **Risk Register:** Update risk descriptions, assessments, or status.

- **Risk Assessment:** Reassess risks when likelihood or impact changes.
- **Risk Treatment:** Modify treatment decisions or actions when necessary.
- **Control Register:** Add, modify, or update controls and their effectiveness evidence.
- **Risk Monitoring and Review:** Update monitoring indicators or review frequencies.

10. Improvement Follow-up

Improvement actions are followed up according to their importance and risk level.

High and Critical risks receive priority.

Open actions must be tracked, delays documented, and overdue or ineffective actions escalated to the responsible authority.

11. Continuous Improvement Outputs

Expected outputs include:

- Documented improvement actions.
- Resolution of identified weaknesses.
- Improved security controls and procedures.
- Updated risk management records.
- **Evidence of implementation and effectiveness.**
- **Lessons Learned** for future risk management activities.

12. Continuous Improvement Cycle

Monitoring and Review → Identify Problems → Analyze Root Causes → Determine Actions → Implement → Verify Effectiveness → Update Documentation → Repeat.

13. Final Note

Continuous Improvement uses monitoring and review results to develop risk management over time.